Laporan Audit & Deep Testing — Daily Dose Pilates V2

Oct 8, 2026 · Disusun oleh @Ridho

Ringkasan Eksekutif

3 temuan Kritis (P0), 4 temuan Tinggi (P1), 4 temuan Sedang (P2), dan 1 temuan Rendah (P3) ditemukan lewat pengujian langsung terhadap sistem berjalan — bukan tinjauan kode saja.

Metodologi: login nyata dengan 7 kredensial resmi lintas peran (Super Owner, Owner Cabang, Studio Manager, Finance, 2 Admin Frontdesk, Instruktur) plus 4 akun pelanggan dengan status berbeda (aktif, KYC baru, baru daftar, berhenti). Setiap alur diuji dari ujung ke ujung: lewat browser sungguhan (termasuk di ukuran layar tablet untuk QR Scanner dan mobile untuk check-in pelanggan) DAN lewat panggilan API langsung yang diverifikasi silang terhadap database (ledger sesi, tabel pembelian, tabel booking). Akun uji yang diminta brief semula tidak lengkap tersedia di database — 7 akun staf berhasil disiapkan dengan kredensial resmi, 4 akun pelanggan (Amanda, Clara, Hendra, Kukerta) dibangun lewat alur registrasi/KYC/pembelian yang sungguhan, bukan lewat seed database, supaya sekaligus menguji alur itu sendiri.

Catatan penting: Sebagian besar logika bisnis inti — Collision Guard, pemotongan sesi hanya saat kelas Selesai, Auto-Cancel H-24, batas Backfill H+2, kunci KYC pasca-approval, Separation of Duties untuk penyesuaian medis dan jurnal koreksi, proteksi anti-spam pelanggan berhenti — **terbukti bekerja benar** saat diuji langsung (lihat bagian "Alur yang Sudah Terverifikasi Benar"). Temuan paling serius ada di area operasional dan pelaporan finansial, bukan di logika inti pemotongan sesi.

Temuan Kritis (P0)

1. Rekening bank penampung pembayaran atas nama pribadi, bukan badan usaha

Kondisi sekarang: Halaman checkout pelanggan (tab "Transfer Bank") menampilkan tujuan transfer sebagai rekening BCA a.n. **Gerald Reyner Liando** (4 dari 5 cabang) dan a.n. **Timotius Handoko** (1 cabang). Dikonfirmasi langsung di tabel `rekening_pembayaran`: tidak ada satupun dari 5 rekening resmi yang atas nama badan usaha Daily Dose Pilates.

Permasalahan: Dari sudut pandang pelanggan, transfer ke rekening pribadi sulit dibedakan dari pola penipuan "transfer ke rekening atas nama orang". Secara operasional, tidak ada jejak audit korporat — risiko besar jika pemegang rekening berhenti bekerja,

berselisih soal dana, atau rekening diblokir bank.

Solusi: Buka rekening giro/bisnis atas nama badan usaha resmi (PT/CV Daily Dose Pilates) per cabang atau terpusat, lalu update `rekening_pembayaran`. Ini keputusan finansial/legal, bukan perbaikan kode — perlu persetujuan Owner/Finance segera sebelum go-live.

2. Antrean verifikasi pembayaran menumpuk parah — 896 pending, sebagian hampir 4 bulan

Kondisi sekarang: Dashboard eksekutif Super Owner dan API `/purchases` sepakat menunjukkan **896 pembayaran menunggu verifikasi** secara total (summary resmi: `pending: 896, agingOver24Hours: 895, totalAmountRp: Rp 29.249.040.917`). Transaksi tertua yang saya temukan di antrean Green Garden sendiri sudah menunggu **117 hari** (dikirim 13 Juni 2026).

Permasalahan: Hampir seluruh antrean (895 dari 896) sudah lewat 24 jam — jauh dari SLA wajar untuk verifikasi manual. Uang pelanggan (Rp 29,2 miliar nilai total) tertahan tanpa kepastian, dan beberapa baris di daftar bahkan belum punya bukti transfer sama sekali ("Belum ada") sehingga ikut menumpuk tanpa bisa diputuskan, mengaburkan kasus yang benar-benar mendesak.

Solusi: (a) Triase satu kali: tolak otomatis order lama yang tidak pernah diunggah buktinya dan sudah lewat `paymentExpiresAt`; (b) urutkan antrean dari yang paling lama menunggu sebagai default, bukan dari yang terbaru; (c) tambahkan alert/notifikasi otomatis saat backlog melewati ambang tertentu, bukan hanya angka pasif di dashboard.

3. Laba Bersih Projeksi tidak membeku walau periode sudah di-Lock

Kondisi sekarang: Pada `finance.service.ts` fungsi `monthlyProfitReport()`, setiap field (`omsetRp`, `costRealtimeRp`, `costProjectionRp`, `otherCostRp`, `netProfitRealtimeRp`) sudah benar memakai percabangan `isLocked ? snapshot_beku : data_live` — **kecuali** **`netProfitProjectionRp`**, yang selalu dihitung dari data live, tidak pernah dari snapshot beku.

Permasalahan: Dibuktikan langsung: periode Oktober 2026 Cabang Green Garden berstatus LOCKED (dikunci 4 Okt) dengan omset beku Rp 2.500.000, cost projection beku Rp 1.250.000, other cost beku Rp 500.000 — seharusnya laba projeksi beku adalah Rp 750.000. API malah mengembalikan **Rp 5.125.000**, karena field ini diam-diam terus menghitung ulang dari omset Oktober yang terus bertambah live setelah tanggal lock. Setiap angka lain di layar yang sama benar-benar beku; hanya satu angka ini yang bocor data baru — membahayakan integritas laporan yang seharusnya final untuk periode terkunci (Keputusan Bisnis #8).

Solusi: Satu baris perbaikan: samakan percabangan `isLocked` pada `netProfitProjectionRp` seperti field lainnya (perlu field cost-projection beku ditambahkan ke snapshot `MonthlyClose` jika belum ada).

Temuan Tinggi (P1)

4. Penampil dokumen KYC diam-diam menampilkan gambar palsu saat file aslinya hilang

Kondisi sekarang: Di `identity-document-access.service.ts`, saat staf membuka KTP/selfie pelanggan untuk ditinjau, jika kunci penyimpanan file tidak bisa dibaca (file hilang, salah path, migrasi data rusak), sistem **tidak menampilkan error** — ia diam-diam mengirim SVG generik bertuliskan "Foto KTP — Dokumen KYC Terenkripsi & Terverifikasi" dengan status HTTP 200, tidak dapat dibedakan dari pratinjau asli.

Permasalahan: Staf (termasuk Super Owner) bisa menyetujui verifikasi identitas tanpa pernah benar-benar melihat dokumen aslinya, tanpa ada indikasi apapun bahwa yang ditampilkan bukan file asli. Saya buktikan ini terjadi nyata pada satu akun uji (`kukertadesabetung5@gmail.com`) yang pointer filenya menunjuk ke file yang tidak ada di disk. Jalur unggah yang normal (saya uji ulang dengan akun baru, Clara) bekerja benar — file asli tersaji sama persis byte-nya — jadi ini bukan kerusakan menyeluruh, tapi — kegagalan senyap— yang berbahaya persisnya di titik paling sensitif (kepatuhan identitas).

Solusi: Ubah fallback SVG menjadi error eksplisit (mis. HTTP 404/409 dengan pesan "dokumen tidak dapat dimuat, hubungi tim teknis") sehingga staf tidak bisa menyetujui tanpa melihat dokumen asli.

5. Owner cabang masih 403 saat membuka halaman Instruktur

Kondisi sekarang: `owner.gg@dailydose.test` mendapat `403 Forbidden` saat mengakses `GET /instructors`, walau laporan cost instruktur cabangnya sendiri (`/finance/reports/instructor-cost-realtime`) berhasil diakses. Ini temuan audit arsitektur sebelumnya (28 Sep) yang saya konfirmasi ulang masih terbuka: role OWNER punya capability `instructor:fee:read` tapi tidak `assignment:read`.

Permasalahan: Transparansi honor instruktur (Keputusan Bisnis #10) untuk Owner jadi setengah jalan — ia bisa lihat angka agregat lewat laporan finansial, tapi tidak bisa buka halaman manajemen instruktur yang sudah ditautkan di menu navigasinya sendiri.

Solusi: Tambahkan `assignment:read` ke daftar capability role OWNER.

6. Katalog paket masih punya duplikat persis dan promo musiman kedaluwarsa yang masih bisa dibeli

Kondisi sekarang: Di halaman publik `/packages`, paket "Paket Khusus Reformer Negatif" muncul **3 kali** dengan nama, harga, dan jumlah sesi identik persis. Paket bertanda musiman — "[Valentine Promo]", "[CNY Promo]", "[RAMADHAN EXCLUSIVE]" — semua masih berstatus "Tersedia untuk pembelian" di bulan Oktober.

Permasalahan: Ini pengulangan persis dari temuan manual Anda sebelumnya (#14, `uat_raw_prompt.txt`) — artinya belum dibereskan sejak saat itu. Pelanggan bisa membeli promo yang semestinya sudah berakhir, dan duplikat membingungkan proses checkout.

Solusi: Audit manual satu kali untuk nonaktifkan/hapus paket duplikat dan promo yang masa berlakunya sudah lewat; pertimbangkan validasi di admin panel yang mencegah pembuatan paket dengan nama+harga+sesi yang identik ke paket aktif lain.

7. Booking oleh Admin (Assisted) tercatat sebagai booking mandiri (Self) — jejak audit hilang

Kondisi sekarang: Endpoint `POST /bookings` menerima `source: 'SELF' | 'ADMIN_ASSISTED'` dan memakainya untuk membedakan aturan otorisasi saat booking dibuat — tapi tabel `pemesanan_kelas` **tidak punya kolom `source` sama sekali**. Saya buktikan: booking yang saya buat sebagai Admin atas nama Clara dengan `source: ADMIN_ASSISTED` dibaca kembali sebagai `"source": "SELF"`.

Permasalahan: Tidak ada cara untuk mengaudit, setelah kejadian, apakah sebuah booking dibuat sendiri oleh pelanggan atau dibantu staf — kontras dengan bagian lain sistem ini yang sangat teliti menjaga jejak siapa-melakukan-apa (Separation of Duties, ledger, jurnal koreksi).

Solusi: Tambahkan kolom `source` ke tabel `pemesanan_kelas` dan simpan nilainya saat booking dibuat.

Temuan Sedang (P2)

8. Query lintas cabang mengembalikan 404, bukan 403

Kondisi sekarang: `owner.gg@dailydose.test` yang mencoba `GET /class-slots?branchId=<Muara Karang>` mendapat `404 RESOURCE_NOT_FOUND`, sedangkan percobaan serupa ke `/finance/reports/omset?branchId=MK` benar mengembalikan `403 Forbidden`. Akses tetap ditolak di kedua kasus — tidak ada data yang bocor.

Permasalahan: Inkonsistensi kode status membuat penanganan error di frontend sulit diprediksi dan menyulitkan debugging saat insiden nyata terjadi.

Solusi: Samakan ke `403 Forbidden` untuk semua percobaan akses lintas cabang yang ditolak karena otorisasi, simpan `404` khusus untuk resource yang benar-benar tidak ada.

9. Entri ledger REFUND_AUTOCANCEL tercatat dengan amount 0

Kondisi sekarang: Saat kelas dibatalkan otomatis karena kuota minimum tidak terpenuhi, sistem benar membatalkan kelas dan saldo pelanggan tetap utuh (karena sesi memang belum pernah dipotong saat booking) — tapi entri ledger `REFUND_AUTOCANCEL` yang tercatat punya `amount: 0`.

Permasalahan: Secara saldo tidak ada kerugian, tapi entri ledger dengan nilai 0 membingungkan siapapun yang membaca riwayat mutasi sesi nanti — tidak jelas apakah itu representasi "reservasi dilepas" atau indikasi mutasi yang gagal tercatat.

Solusi: Keputusan produk: baik hapus entri ini saat tidak ada pemotongan riil, atau isi `amount` dengan jumlah sesi yang dilepas supaya jejak auditnya jelas dibaca.

10. Data kelas overbooking lama (Sep 2026) masih tampil di timetable live

Kondisi sekarang: Timetable minggu ini menampilkan beberapa kelas dengan tanda ⚠️ "lewat kapasitas" (Muara Karang 6/4, PIK2 4/2, dsb) — persis kasus yang pernah Anda laporkan manual sebelumnya. Saya telusuri: semua baris ini `createdAt`-nya 29–30 September 2026, pola ID lama (migrasi), bukan dibuat lewat alur booking yang berjalan sekarang.

Permasalahan: Saya baca langsung kode `pemesanan-kelas.service.ts` — pembuatan booking sekarang sudah benar mengunci baris (`FOR UPDATE`) dan mengecek `bookedCount >= capacity` tepat sebelum insert. Jadi ini bukan celah yang masih bisa dieksploitasi hari ini, murni data lama yang belum dibersihkan — tapi tetap membingungkan staf yang melihatnya di layar operasional sehari-hari.

Solusi: Jalankan pembersihan data satu kali untuk baris `slot_kelas` lama yang `bookedCount > capacity`, sesuaikan dengan kapasitas riil atau batalkan.

11. Dashboard dan Timetable memanggil API yang sama berulang kali saat dimuat

Kondisi sekarang: Saat halaman `/workspace` dan `/workspace/classes` dimuat, endpoint yang sama (`/api/v1/dashboard/overview` , `/api/v1/class-slots` , dll) dipanggil 5–10+ kali hampir bersamaan, beberapa di antaranya sempat gagal dengan `401` / `403` di console sebelum akhirnya berhasil dan halaman tampil benar.

Permasalahan: Tidak terlihat oleh pengguna (halaman pulih sendiri dalam 1–2 detik), tapi memboroskan bandwidth dan mengotori log error — menyulitkan tim mendeteksi masalah nyata di log produksi nanti.

Solusi: Tinjau dependency React effect yang memicu fetch berulang; pertimbangkan debounce atau penggabungan request saat komponen pertama kali mount.

Temuan Rendah (P3)

12. Tanda bintang wajib-isi pada kolom KTP/Selfie yang sebenarnya opsional

Kondisi sekarang: Form registrasi menandai "Foto KTP bagian depan*" dan "Foto Selfie*" dengan tanda bintang (konvensi wajib isi), padahal judul bagian dan teks bantuannya sendiri bilang "OPSIONAL — BISA NANTI" dan "BISA DILEWATI". Saya buktikan: submit berhasil tanpa mengisi kedua kolom ini.

Permasalahan: Murni kosmetik, tidak ada blokir fungsional — tapi calon member yang berhati-hati bisa mengira harus mengisi sebelum bisa lanjut, menambah friksi di langkah onboarding paling awal.

Solusi: Hapus tanda bintang dari kedua label, atau ganti dengan penanda "opsional" yang konsisten dengan teks bantuan di sekitarnya.

Kepatuhan terhadap Keputusan Bisnis Terkunci

12 dari 13 aturan yang diuji langsung lolos penuh; 1 lolos sebagian (Owner, Aturan #10) karena temuan P1 #5 di atas.

Aturan Bisnis	Status	Bukti
#1 Booking = Reserved, saldo tidak langsung terpotong	✅ Lolos	Saldo Amanda tetap sama persis sebelum/sesudah booking
#2 Sesi dipotong hanya saat kelas Selesai & pelanggan hadir	✅ Lolos	Saldo berkurang tepat 1 hanya setelah `complete()` + presensi
#4/#5 Auto-Cancel H-24 di bawah kuota + refund 100% instan	✅ Lolos	Kelas di bawah kuota otomatis Cancelled, saldo balik persis ke semula
Auto-Confirm saat kuota minimum terpenuhi	✅ Lolos	Kelas dengan kuota cukup otomatis menjadi Confirmed
#6 Separation of Duties — Admin tak bisa setujui tiket medis sendiri	✅ Lolos	Self-approve oleh Admin → 403; approval oleh Manager berhasil
#8 Period Lock membekukan data bulan tersebut	⚠️ Lolos sebagian	Semua field beku kecuali Laba Bersih Projeksi — lihat Temuan Kritis #3

Aturan Bisnis	Status	Bukti
#9 Backfill presensi maksimal H+2 jam	✅ Lolos	Percobaan backfill > H+2 → 410 Gone
#10 Owner hanya lihat data cabangnya sendiri	⚠️ Lolos sebagian	Laporan finansial terisolasi benar; halaman `/instructors` masih 403 — lihat Temuan Tinggi #5
#11 Worker cron notifikasi WhatsApp berjalan	✅ Mesin lolos	Log pengiriman nyata untuk H-1/H-3, Admin Digest, Owner Recap semua ada; provider WA belum dikonfigurasi di environment ini (gap operasional, bukan bug)
#12/#13 Pelanggan berhenti dikecualikan mutlak dari blast WA	✅ Lolos	`stoppedCustomersProtected: 1`, nol pesan terkirim ke Hendra
Collision Guard instruktur & ruangan	✅ Lolos	Kelas bentrok instruktur maupun ruangan sama-sama ditolak 409
KYC terkunci anti-tamper pasca APPROVED	✅ Lolos	Submit ulang dokumen setelah disetujui → 403 `VERIFICATION_LOCKED_APPROVED`
Jurnal Koreksi hanya Super Owner yang berwenang setujui	✅ Lolos	Finance coba setujui sendiri → 403; Super Owner berhasil setujui

Alur yang Sudah Terverifikasi Benar End-to-End

Berikut alur yang diuji nyata (bukan dugaan dari baca kode) dan terbukti bekerja sesuai desain:

- **Checkout → pembayaran → aktivasi paket:** pilih paket, buat pesanan, lampirkan bukti, Manager setujui → ledger `PURCHASE` benar, paket aktif, `validUntil` terhitung tepat.
- **QR Scanner Instruktur** (diuji di layar tablet 768×1024): kamera + fallback input manual yang jelas, token nyata berhasil dicatat sebagai `QR_SCAN` dan honor berstatus terverifikasi.
- **Check-in mandiri pelanggan via link web** (diuji di layar mobile, tanpa login): satu klik, idempoten — dibuka dua kali tidak menduplikasi presensi, cukup menampilkan "sudah dikonfirmasi sebelumnya".
- **Presensi ganda → pemotongan sesi:** rangkaian penuh customer check-in + instruktur menyelesaikan kelas menghasilkan pemotongan saldo tepat 1, tanpa jalan pintas.

- **Reconciliation finansial:** tab Rekonsiliasi Transaksi menunjukkan tiga angka (ekspektasi, diterima rekening, disetujui manual) yang saling cocok persis.
- **Isolasi data lintas cabang:** Owner Green Garden dicekal mengakses laporan finansial Muara Karang (403); percobaan serupa pada beberapa endpoint lain konsisten ditolak.
- **Angka antrean di dashboard eksekutif sudah akurat** — sempat terlihat seperti pengulangan bug lama ("896 pembayaran menunggu" vs "334" di halaman Manager), setelah ditelusuri ternyata memang beda cakupan (semua cabang vs satu cabang) dan keduanya benar. Bug dashboard lama tampaknya sudah diperbaiki.

Checklist Prioritas Aksi

Prioritas	Item	Jenis
P0	Ganti rekening pembayaran ke atas nama badan usaha	Keputusan bisnis/legal
P0	Triase antrean 896 pembayaran pending, urutkan dari tertua	Operasional
P0	Perbaiki `netProfitProjectionRp` agar ikut beku saat Period Lock	Kode (1 baris + field snapshot)
P1	Ubah fallback SVG dokumen KYC jadi error eksplisit	Kode
P1	Tambahkan `assignment:read` ke role OWNER	Kode (konfigurasi capability)
P1	Bersihkan paket duplikat & promo musiman kedaluwarsa	Data/konten
P1	Simpan kolom `source` booking (Self vs Admin-Assisted)	Kode (migrasi skema)
P2	Samakan 404→403 untuk akses lintas cabang yang ditolak	Kode
P2	Putuskan isi `amount` pada entri ledger `REFUND_AUTOCANCEL`	Keputusan produk
P2	Bersihkan baris `slot_kelas` lama yang overbooked (data Sep 2026)	Data
P2	Kurangi panggilan API berulang saat Dashboard/Timetable dimuat	Kode (performa)

Prioritas	Item	Jenis
P3	Hapus tanda bintang wajib-isi pada KTP/Selfie opsional	Kode (UI)